SIMATS ENGINEERING

ASSESSMENT TOOL 3 – SCENARIO-BASED ASSESSMENT

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

STUDENT NAME: G. PRANATHI

REGISTER NUMBER: 192472237

QUESTION 1: FOOTPRINTING TOOLS – CONDUCTING COMPETITIVE INTELLIGENCE

1.1 Introduction

Every organization leaves a trail of information on the internet. Domain records, published contact pages, website technologies and security certificates all describe how a company presents itself online. **Footprinting** is the systematic collection of this information, and it is normally the first stage of an ethical hacking engagement because it shows the assessor what an outsider can learn before any technical testing begins.

Competitive intelligence, in a security setting, means studying publicly available information about an organization to understand its digital presence, its technology choices and the exposure these create. The aim is not to attack the organization but to help it see itself the way an outsider would, and to close unnecessary gaps.

In this scenario a cybersecurity consultant is engaged by ABC Technologies to carry out an assessment that must not touch the company's own servers. The consultant has to discover four things: how the company's domain is registered, which employee email addresses are public, which technologies the public website uses, and which subdomains are visible. Because direct contact with the target is forbidden, the work is entirely **passive footprinting** and relies on third-party records and public indexes.

1.2 Objectives

The assessment is designed to achieve the following objectives:

1. Establish the registration profile of the ABC Technologies domain.
2. Locate employee and departmental email addresses that are visible to the public.
3. Profile the software and services behind the company's public website.
4. Compile a list of publicly visible subdomains and hostnames.
5. Show how each tool contributes to a combined picture of the organization's exposure.

6. Explain the risks that each category of exposed information can create.
7. Recommend practical steps that reduce unnecessary disclosure.

1.3 Analysis of the Scenario

The key restriction in the scenario is that the consultant may not interact directly with ABC Technologies' infrastructure. This shapes every tool choice. Tools that query the company's own web, mail or DNS servers are excluded, while tools that read from registries, search indexes, public logs and commercial data collections are suitable.

The table below maps each information requirement to the most suitable passive source.

Requirement	Passive tool or source	What it reveals
Domain registration	WHOIS, ICANN Lookup, RDAP	Registrar, dates, status codes, name servers
Employee emails	Search-engine operators, Hunter.io	Published addresses and naming pattern
Technology stack	Wappalyzer, BuiltWith	CMS, frameworks, analytics, hosting indicators
Public subdomains	Certificate Transparency, passive DNS, search engines	Hostnames that appear in public records

Since the scenario does not state the actual domain of ABC Technologies, the examples in this report use the reserved placeholder domain example.com. They demonstrate the method only and must not be read as findings about the company.

1.3.1 Business Intelligence in Public Information

Competitive intelligence is wider than technical data. Many ordinary business documents describe technology and structure, and an assessor should consider them because an attacker certainly would.

Public source	What it can reveal	Security relevance
Job advertisements	Products, platforms and tools the company uses	Indicates technology in use and skill gaps
Press releases and news	New services, partners and acquisitions	Shows new assets that may be incompletely secured
Partner and vendor pages	Third-party suppliers	Supplier relationships can be abused for impersonation
Conference talks and slides	Architecture diagrams and project names	May disclose internal naming and design
Social media profiles	Staff roles, office photos, events	Supports convincing social engineering messages

1.3.2 Criteria for Selecting Tools

The consultant chooses tools that match the scenario rules and the quality of evidence required. The main criteria are shown below.

Criterion	Reason it matters
Passive operation	The tool must read stored data and not contact the target
Data provenance	The origin and age of the data must be known
Repeatability	Another analyst should reach the same result
Output quality	Results should include source links and timestamps
Cost and limits	Free tiers may restrict searches, which affects coverage

1.4 Passive and Active Footprinting Compared

Understanding the boundary between the two approaches is essential for staying within scope. Passive footprinting gathers what already exists in public records. Active footprinting generates new traffic to the target and can be logged, blocked or interpreted as hostile activity.

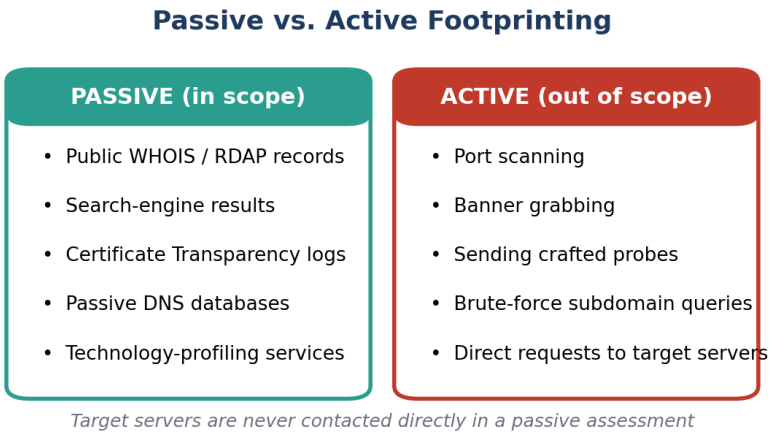


Figure 1.1: Passive and active footprinting compared.

Only the left-hand column is permitted here. If the consultant later wished to move into active techniques, the engagement agreement would need to be extended in writing.

1.5 Assessment Workflow

A structured sequence avoids duplicated effort and keeps the evidence trail clean. The consultant first confirms the official domain, then works through registration, email, technology and subdomain sources in turn, and finishes by compiling a report.

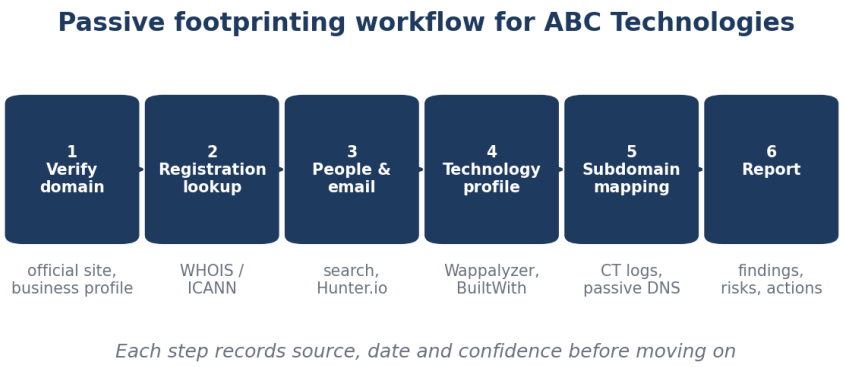


Figure 1.2: Passive footprinting workflow.

At each stage the consultant records the source, the date of collection and a confidence rating. Doing so means that any finding can be repeated and checked by another analyst.

1.5.1 Task checklist for the consultant

Phase	Task	Evidence to keep
Preparation	Obtain written authorization and confirm scope	Signed scope document
Domain check	Verify official domain from company material	Page address and date
Registration	Run lookup and note registrar, dates, locks, name servers	Saved lookup output
Email	Run domain-restricted searches and a Hunter.io query	URLs and screenshots with dates
Technology	Profile the public site with two tools and compare	Tool reports
Subdomains	Search CT logs and passive DNS, then merge lists	Source list and timestamps
Reporting	Rate findings and draft recommendations	Findings register

1.6 Domain Registration Details Using WHOIS and ICANN Lookup

1.6.1 Purpose of the tool

WHOIS and its modern replacement RDAP are public query services that return registration data held by registries and registrars. For many generic top-level domains, ICANN Lookup provides a convenient web front end to the same data.

1.6.2 Fields commonly returned

Depending on registry policy and privacy settings, a lookup may return the fields below. Many registrants now hide personal details behind a privacy service.

Field	Meaning	Why an analyst reads it
Registrar	Company through which the domain was bought	Identifies who controls renewals and changes
Creation date	When the domain was first registered	Gives context on the age of the domain

Field	Meaning	Why an analyst reads it
Expiry date	When registration lapses	Lapsed domains can be taken over by others
Status codes	Locks such as clientTransferProhibited	Shows protection against unauthorised transfer
Name servers	Hosts that answer DNS for the domain	Leads to the DNS provider and later checks
Registrant	Owner or privacy proxy	Confirms organisational ownership when visible

1.6.3 Applying the tool

The consultant first confirms the official domain from the company's own public material. A lookup is then run from the command line or through a web service. The example below uses a placeholder domain.

```
$ whois example.com
$ whois -h whois.iana.org example.com
```

Domain Registration Lookup (illustrative record)

Domain	example.com
Registrar	Example Registrar, Inc.
Created	1995-08-14
Expires	2027-08-13
Last updated	2026-01-15
Status	clientTransferProhibited
Name servers	ns1.example.com / ns2.example.com
Registrant	REDACTED FOR PRIVACY
DNSSEC	unsigned

Figure 1.3: Illustrative registration record for a placeholder domain.

1.6.4 Security meaning and limits

Registration data helps verify that the domain belongs to the organization, that locks are in place and that renewal is managed. An unexpected change of registrar or name servers deserves investigation because it can signal domain hijacking. At the same time, a redacted record is common and legitimate, and a recent creation date does not itself indicate malicious intent. Registration data gives context; it is not proof of a weakness.

1.7 Employee Email Discovery Using Search Engines and Hunter.io

1.7.1 Why email exposure matters

Email addresses act as usernames for many business systems and are the main entry point for phishing. Knowing which addresses are public helps the organization judge how easily outsiders can build a target list.

1.7.2 Search-engine techniques

Search operators narrow results to the target domain and to document types that often contain contact details, such as PDF brochures, event pages and press releases. Illustrative queries are shown below with the placeholder domain.

```
site:example.com "contact"
site:example.com filetype:pdf "@example.com"
"@example.com" "sales" OR "support"
```

1.7.3 Hunter.io

Hunter.io is a service that collects publicly associated business email addresses and infers the naming convention used by an organization, for example first.last at the domain. Results usually include a confidence indicator and links to the pages where an address was found. The consultant should separate addresses that were actually published from addresses that were only inferred from the pattern, because the second group may not exist.

1.7.4 Handling of discovered data

- Record the page URL and the date for every address found.
- Store only what is necessary for the report and protect it with access control.
- Do not send test messages or attempt to sign in to any account.
- Mask personal addresses in the final report where the finding can be shown without them.

1.7.5 Risks and countermeasures

Risk	How it arises	Countermeasure
Targeted phishing	Attackers address staff by name and role	Awareness training and reporting button
Email spoofing	Attackers imitate the company domain	SPF, DKIM and DMARC enforcement
Spam and harvesting	Addresses published in plain text	Use role mailboxes and contact forms
Account takeover	Known usernames enable password guessing	Multi-factor authentication and lockout rules

1.8 Technology Stack Identification Using Wappalyzer and BuiltWith

1.8.1 What a technology stack is

A technology stack is the set of software layers that deliver a website: the content management system, programming frameworks, web server, analytics scripts, hosting and security services. Every layer needs patching and configuration, so a stack inventory is also a maintenance checklist.

1.8.2 The two tools

Wappalyzer is a browser extension and lookup service that recognizes technologies from page markup, scripts, cookies and response headers that any visitor's browser already receives. **BuiltWith** maintains a large database of technology usage collected by crawling the web, and also records historical changes. Because their detection methods and refresh cycles differ, the two tools may disagree, which is why using both is recommended.

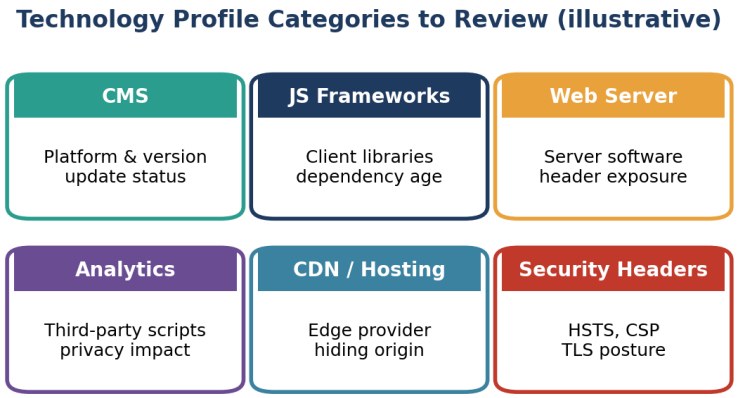


Figure 1.4: Technology categories reviewed in a stack profile (illustrative).

1.8.3 Recording the result

Category	What is recorded	Follow-up question
CMS	Product name and version if visible	Is this version still supported?
JavaScript libraries	Frameworks and their versions	Are known issues fixed in later releases?
Analytics and tags	Third-party script providers	Is each provider approved and needed?
CDN and hosting	Provider indicators	Is the origin server properly shielded?
Security headers	HSTS, CSP, TLS version	Are the protections correctly configured?

These rows are categories to examine, not facts about ABC Technologies.

1.8.4 Significance and limitations

A stack profile lets the organization compare what is publicly visible with what it believes it runs. If an outdated component is detected, the next step is to check internally whether the version is really in use. Attackers use the same data to choose methods, so avoiding unnecessary version banners is a sensible hardening step. Profiling tools see only what is exposed; reverse proxies, caching layers and custom

builds can hide components, and some detections are third-party services rather than company-managed software. The result is therefore an indication, not a full inventory.

1.9 Public Subdomain Discovery Using Certificate Transparency and Passive Sources

1.9.1 Why subdomains matter

A subdomain is a hostname beneath the main domain, such as portal.example.com. Companies use them for staff portals, APIs, testing and documentation. Forgotten subdomains are a recurring source of exposure because nobody monitors them.

1.9.2 Sources used

Certificate Transparency (CT) logs are public records of issued TLS certificates. Because each certificate lists the hostnames it covers, a search can reveal names that are not linked from the main website. **Passive DNS** databases store historical DNS answers collected by sensors elsewhere on the internet, so they can show hostnames that once resolved. **Search-engine indexing** can expose pages hosted on additional subdomains.

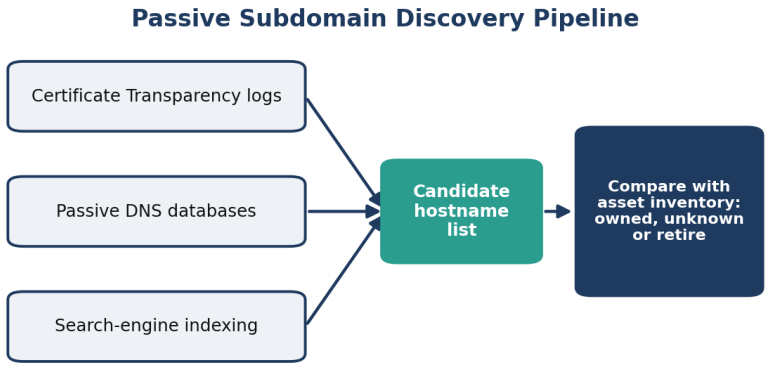


Figure 1.5: Passive subdomain discovery pipeline.

1.9.3 Method

1. Confirm the parent domain.
2. Query CT search services for certificates containing the parent domain.
3. Cross-check names in a passive DNS source.
4. Run domain-restricted search queries for indexed pages.
5. Merge results and remove duplicates and unrelated domains.
6. Rate confidence for each name and pass the list to the client for ownership checks.

1.9.4 Associated risks

Risk	Description
Forgotten assets	Old systems remain online without patching or monitoring
Development exposure	Test or staging hosts may lack production-grade access control
Subdomain takeover	A record still points to a cancelled third-party service that someone else can claim
Information disclosure	Names such as vpn or admin reveal internal purpose and naming habits
Certificate leakage	Hostnames in public certificates expose planned or private services

A discovered name is only a lead. It does not prove that a service is reachable or vulnerable, and the client must verify each one.

1.10 Contribution of the Tools to Competitive Intelligence

No single tool gives the full picture. The strength of the method lies in combining sources and checking one against another.

Tool	Data type	Contribution
WHOIS / ICANN	Registration metadata	Confirms ownership and lock status
Search engines	Indexed pages	Reveals contacts and extra hosts
Hunter.io	Email patterns	Shows how visible staff addresses are
Wappalyzer	Live site technologies	Flags components needing review
BuiltWith	Historical technology data	Adds trend and context
CT logs	Certificate names	Exposes hostnames not linked publicly
Passive DNS	Historic DNS answers	Finds previously active hostnames

1.10.1 Illustrative walk-through

To show how the tools combine, consider a purely hypothetical case using the placeholder domain example.com. A registration lookup shows that the domain has a registrar lock and two name servers, which suggests basic protection. A search for published contact information reveals only a generic sales mailbox and a contact form, which is a good sign. Wappalyzer indicates a popular content management system and an analytics script, so the version is added to the list of items to verify internally. A CT search shows a certificate that also covers a staging hostname, and passive DNS records that this name resolved to an address in the company range last year. The consultant then writes four findings, each with source and confidence, and recommends that the client confirm whether the staging system is still needed. No single tool produced that conclusion; it came from comparing results.

For example, a CT search may reveal a hostname that the website never links to, Wappalyzer may show which platform serves it, and the registration data may show who manages DNS for it. Together these form a coherent exposure profile.

1.11 Selecting and Validating Sources

Passive intelligence is only as reliable as the sources behind it. Registries are authoritative for registration facts, while commercial datasets and crawlers can be incomplete or out of date. The consultant should therefore apply a few simple tests before relying on any observation.

Test	Question asked	Example of use
Authority	Does the source hold the original data?	Registry record versus a third-party summary
Freshness	When was the record collected?	Old crawl showing a service that no longer exists
Corroboration	Does a second independent source agree?	CT entry confirmed by passive DNS
Relevance	Does the item truly belong to ABC Technologies?	Similar-looking domain owned by another company
Legality	Was the source lawfully published?	Avoid leaked or stolen data collections

Findings that fail one or more tests are not discarded but are marked with lower confidence so that the client does not act on weak evidence.

1.11.1 Avoiding false positives

Name similarity is a common trap. A domain that resembles the client's brand may belong to an unrelated company, a reseller or even a registrant who is deliberately imitating the brand. The consultant should check registration details, hosting information and site content before attributing any domain to ABC Technologies. Where look-alike domains do appear to be hostile, they should be reported separately as a brand-protection matter rather than as a weakness of the client's own infrastructure.

1.12 Rating the Exposure

Once findings are collected they need to be ranked so the client can decide what to fix first. A simple likelihood and impact matrix is adequate for passive findings, where no technical vulnerability has been proven.

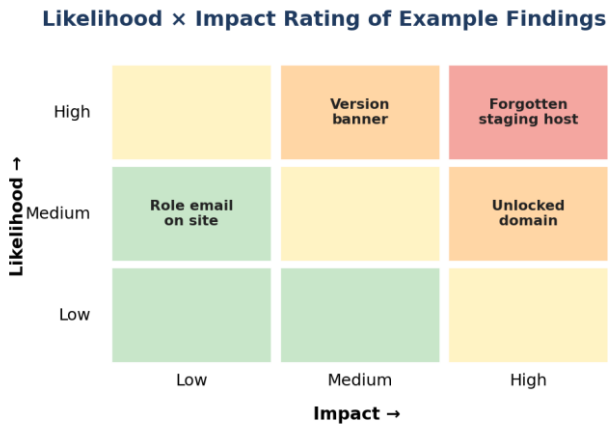


Figure 1.6: Likelihood and impact rating of example findings (illustrative).

Finding type	Likelihood	Impact	Priority
Forgotten staging hostname	High	High	Fix first
Detailed version banner	High	Medium	Fix soon
Domain without registrar lock	Medium	High	Fix soon
Named staff email on a public page	Medium	Low	Plan and monitor

Ratings reflect exposure only. They are revised when internal verification confirms or removes the concern.

1.13 Documentation of Findings

Results should be written into a findings register so that each observation can be traced and verified. A suggested layout is shown below, with one example row built on placeholder data.

ID	Category	Observed value	Source	Confidence	Action
F-01	Subdomain	dev.example.com (placeholder)	CT log search	Medium	Client to confirm owner and access controls
F-02	Email	Role address on contact page (placeholder)	Search engine	High	Keep; consider contact form
F-03	Technology	CMS name only (placeholder)	Wappalyzer	Low	Verify version internally

As no domain is supplied in the scenario, genuine entries cannot be created. In a live engagement the table must hold only verified observations.

1.14 Ethical and Legal Considerations

- Work only inside the written scope agreed with ABC Technologies.
- Use public sources and respect the terms of each service.
- Do not attempt to log in, guess passwords or bypass access controls.
- Collect only the personal data that the report needs and secure it.
- Report any sensitive discovery, such as leaked credentials, to the client immediately and privately.

In India, unauthorised access to computer systems is addressed by the Information Technology Act, 2000, while handling of personal data is governed by the Digital Personal Data Protection Act, 2023. Other jurisdictions have comparable laws. Even though passive footprinting uses public information, the consultant must still keep personal details secure and use them only for the agreed purpose. Written

authorization from ABC Technologies, a defined scope and a named contact for escalation are the minimum safeguards for a lawful engagement.

1.15 Recommended Measures for ABC Technologies

- Keep registrar accounts protected with multi-factor authentication and enable registrar locks.
- Use role-based contact addresses and a web form instead of listing named staff.
- Enforce SPF, DKIM and DMARC for the company domain.
- Maintain an asset inventory and retire unused subdomains and DNS records.
- Remove version banners and keep every public component patched.
- Review CT log entries regularly so new certificates can be recognised.
- Repeat the passive review at least once a year.

The measures can be sequenced into a short roadmap so that the client sees quick wins early.

Timeframe	Action	Owner
First 30 days	Enable registrar lock and MFA; list all public subdomains and confirm owners	IT administrator
31 to 60 days	Remove unused DNS records; replace named emails with role addresses; enforce DMARC	Network and mail teams
61 to 90 days	Patch or retire outdated public components; hide version banners; set CT monitoring	Web and security teams
Ongoing	Repeat passive review yearly and after major changes	Security manager

1.16 Limitations of the Assessment

A passive review has natural limits. It cannot see systems that never appear in public records, it cannot confirm that a discovered service is running or vulnerable, and it depends on the coverage of third-party datasets. Information may be delayed, so a recent change at ABC Technologies might not yet be visible. The conclusions therefore describe visible exposure at the time of collection and should be refreshed regularly. Any further testing that touches the company's servers would need separate written approval.

1.17 Conclusion

Passive footprinting allows a consultant to describe an organization's public exposure without sending any traffic to its servers. WHOIS and ICANN Lookup provide the registration context, search engines and Hunter.io show what email information is visible, Wappalyzer and BuiltWith describe the website's technologies, and Certificate Transparency and passive DNS reveal hostnames. Each source has limits, so findings must be cross-checked and labelled with a confidence level. Used responsibly, the results

guide ABC Technologies toward practical improvements such as tidier DNS, fewer exposed contacts and better patching.

QUESTION 2: DNS ZONE TRANSFERS

2.1 Introduction

The Domain Name System turns human-friendly names into the numeric addresses that computers use. Almost every online service, including websites, email delivery and remote access, depends on DNS answering correctly and promptly. For that reason organizations run more than one authoritative name server, and those servers must keep identical copies of the data.

The mechanism used to copy a complete zone from one authoritative server to another is called a **zone transfer**. It is a normal and necessary function, but it was designed for trusted servers only. If a name server hands a full copy of its zone to anyone who asks, an outsider obtains a ready-made map of the organization's hosts.

In this scenario a security analyst working under an authorized penetration test suspects that the target's DNS server allows unauthorized zone transfers. The analyst must choose a suitable DNS tool to test the suspicion and explain the consequences. The **dig** utility is the appropriate choice because it can send precisely crafted DNS queries, including full-zone requests, and shows the raw response.

2.2 Objectives

1. Explain what a DNS zone is and why zone transfers exist.
2. Describe the role of the dig command in DNS analysis.
3. Show how an authorized tester checks whether AXFR is permitted.
4. Interpret both a successful and a refused transfer.
5. Explain how leaked zone data helps an attacker plan.
6. Recommend controls that stop unauthorized transfers.
7. Describe verification and reporting steps after remediation.

2.3 DNS Zones and Records

A zone is the part of the DNS namespace that one administrative authority manages. It is stored as a set of resource records, each describing one fact about the domain. A zone for a company might contain the following record types.

Record	Function	Example content
SOA	Start of authority; zone serial and timers	Primary server and admin contact
NS	Lists authoritative name servers	ns1 and ns2 of the organization
A / AAAA	Maps a name to an IPv4 / IPv6 address	www points to a web server
MX	Identifies mail servers	mail host and priority
CNAME	Alias to another name	shop points to a hosting provider
TXT	Free text, often SPF and verification	SPF policy, domain verification tokens

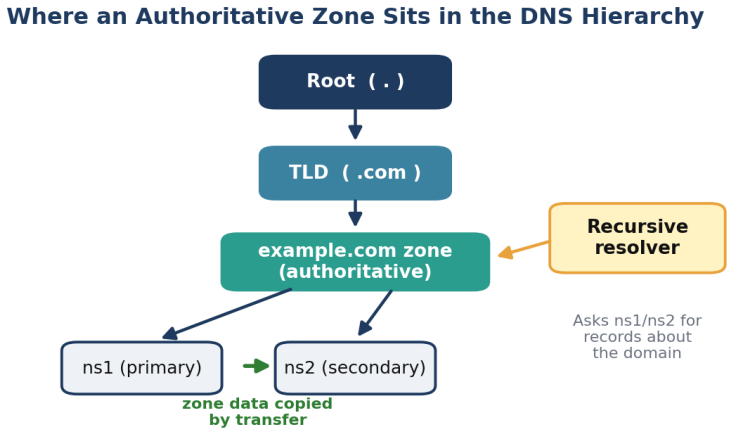


Figure 2.1: Position of an authoritative zone in the DNS hierarchy.

Public zones should contain only records that outsiders genuinely need. Internal hostnames, test machines and management interfaces should be kept in a separate internal zone.

2.4 Types of Zone Transfer

Type	Meaning	Typical use
AXFR	Full zone transfer; the whole zone is copied	Initial synchronisation of a secondary server
IXFR	Incremental transfer; only changes are sent	Efficient updates after small edits

A secondary server normally learns that the zone has changed through a notification or by checking the SOA serial number, and then requests an AXFR or IXFR from the primary. The risk lies in the primary answering such requests from clients that are not real secondaries.

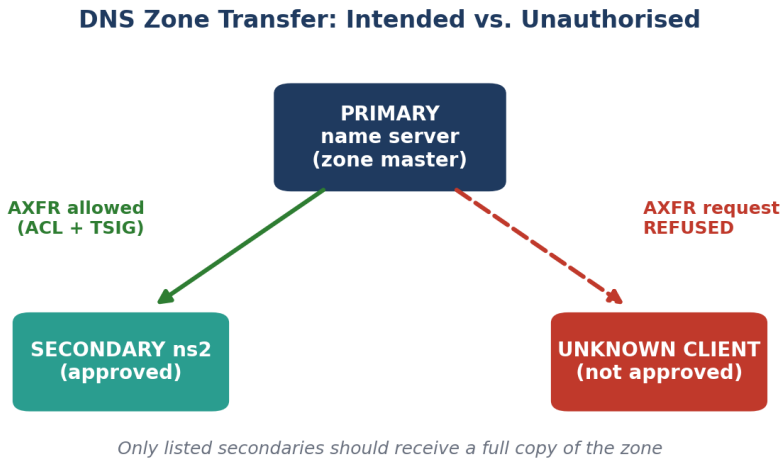


Figure 2.2: Intended and unauthorised zone-transfer paths.

2.5 The dig Utility

dig, the Domain Information Groper, is a command-line tool distributed with the BIND software and available for most operating systems. It sends a query to a chosen DNS server and prints the full response including flags, sections and status codes, which makes it more informative than simple lookup tools.

2.5.1 Common uses

- Look up A, AAAA, MX, NS, TXT and SOA records.
- Send queries directly to a particular name server using the @ symbol.
- Display response codes such as NOERROR, NXDOMAIN and REFUSED.
- Request a zone transfer with the AXFR query type.
- Trace delegation from the root downwards using +trace.
- Confirm that configuration changes behave as intended.

2.5.2 Reasons for choosing dig

dig gives precise control over the query type and target server, produces output that is easy to record as evidence, and is available on common testing platforms. These properties make it the usual choice for checking zone-transfer behaviour.

2.5.3 Reading dig output

Because dig prints the full response, the analyst needs to know how to read its main parts. The status field and flags often decide how a result is classified.

Part of output	Meaning	Why it matters in a transfer test
status: NOERROR	Query was answered normally	Normal answer; records may follow

Part of output	Meaning	Why it matters in a transfer test
status: REFUSED	Server declined to answer	Expected response to an unapproved AXFR
status: NXDOMAIN	Name does not exist	Wrong domain or typing error in the scope
flag aa	Answer is authoritative	Confirms the server is a zone authority
SOA serial	Version number of the zone	Used to compare primary and secondary copies
Transfer failed	dig could not complete the transfer	Indicates the server blocked or dropped the request

2.5.4 Useful dig commands

Command	Purpose
dig example.com A	Look up the IPv4 address
dig +short NS example.com	List name servers briefly
dig example.com SOA @ns1.example.com	Ask a specific server for the SOA record
dig +trace example.com	Follow delegation from the root
dig AXFR example.com @ns1.example.com	Request a full zone transfer (authorized tests only)

2.6 Testing for Zone Transfer Permissions

2.6.1 Preparation

Before any request is sent, the analyst must confirm in writing that the domain and each name server are inside the agreed scope. Only servers that the client has named may be queried. The analyst should also note the date, time and source address of the test so the client can match it with their logs.

2.6.2 Procedure

1. Identify the target domain from the scope document.
2. Discover its authoritative name servers.
3. Pick a name server that is explicitly in scope.
4. Send an AXFR request to that server.
5. Examine the response to see whether records or an error are returned.
6. Repeat for each in-scope name server, because settings can differ between them.
7. Record the exact command and output as evidence.

```
# Step 2 - find the authoritative name servers
$ dig +short NS example.com

# Step 4 - request the full zone from an in-scope server
$ dig AXFR example.com @ns1.example.com
```

The names example.com and ns1.example.com are placeholders. They must be replaced only with the domain and server named in the authorization.

2.6.3 Reading a successful transfer

If the server returns record after record and ends with a second SOA record, the transfer succeeded. Figure 2.3 shows an illustrative result that uses reserved documentation addresses.

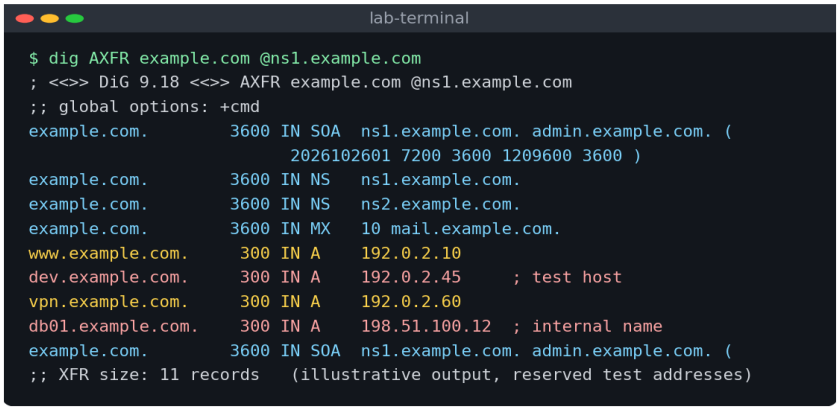


Figure 2.3: Illustrative successful AXFR response (placeholder data).

A successful answer is not always a defect, because some transfers are deliberately enabled for approved secondaries. It becomes a finding when a client that has no business receiving the zone is served.

2.6.4 Reading a refused transfer

A secure server will normally refuse the request, which dig reports as a failed transfer or a REFUSED status.

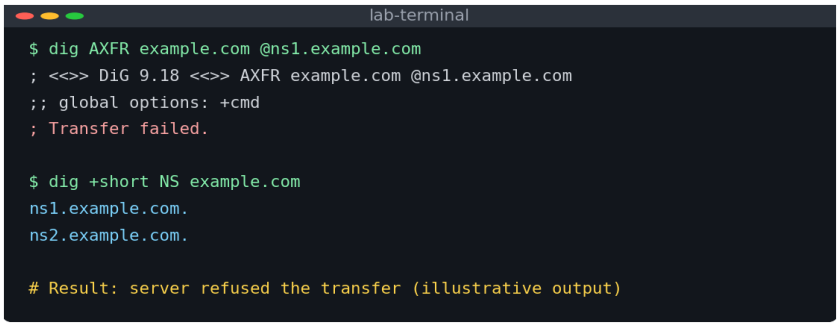


Figure 2.4: Illustrative refused AXFR request.

A refusal is the expected result for an unapproved requester. The analyst should still note that other servers and other zones need to be tested, because a single refusal does not prove the whole DNS estate is correct.

2.6.5 Common mistakes in testing

- Testing a name server that is not named in the authorization.
- Assuming that one refusal covers every server, when secondaries can be configured differently.
- Forgetting to test additional zones such as reverse lookup zones.
- Not saving the exact command and output, which weakens the evidence.
- Sending repeated requests that look like an attack to the client's monitoring team.

2.7 Interpreting the Returned Records

If a transfer succeeds the analyst reads the contents to judge what an outsider could learn. The illustrative output in Figure 2.3 includes ordinary public names but also entries that should not be public, such as a development host and an internal database name.

Observation in zone	What an attacker infers	Concern level
Hostnames like dev, test, staging	Weakly protected pre-production systems	High
Names like vpn, remote, admin	Remote access and management entry points	High
Internal database or file-server names	Layout of the private network	High
Many A records in a small range	Approximate size of the network	Medium
MX and TXT records	Mail providers and third-party services	Low to medium

2.7.1 Severity assessment

Severity depends on what the zone actually contains, not simply on whether a transfer worked. The analyst weighs the sensitivity of the exposed names, how many there are and whether the zone can be linked to systems that matter to the business.

Situation	Typical rating	Reason
Transfer refused to unapproved client	No finding	Control works as intended
Transfer allowed but only public names present	Low	Limited extra knowledge for an attacker
Transfer allowed with test and staging names	Medium	Reveals weakly protected systems
Transfer allowed with internal and management names	High	Exposes network layout and sensitive services

2.8 Impact on Reconnaissance

A full zone is far more efficient than guessing hostnames one by one. It tells an attacker exactly which systems exist, which address ranges are in use and what purpose each host has. This shortens the reconnaissance phase and allows attention to focus on the weakest-looking systems. The transfer itself does not damage anything, but the information it contains lowers the cost of every later step.

For example, an attacker who sees a record labelled for a test web server can search for default credentials or unpatched components on that machine, while a name suggesting an internal file server reveals which addresses sit behind the firewall.

Defenders should also remember that some attackers do not need zone transfers at all, since they can obtain many of the same names from public certificate logs and passive DNS data, as discussed in Question 1. Closing the transfer path is necessary but should be combined with careful control of what the public zone contains.

2.9 Causes of Misconfiguration

- Default settings that allow transfers to any requester.
- Use of broad address ranges instead of exact secondary addresses.
- Old secondary servers that were decommissioned but are still listed.
- Public and internal records mixed in one zone.
- Lack of review after migrating to a new DNS provider.
- No alerting when transfer requests arrive from unknown sources.

2.9.1 Illustrative scenario

Consider a hypothetical company that moved its DNS hosting to a new provider. The migration copied the zone but also copied an old permissive setting that allowed transfers to any address. A secondary server that had been retired two years earlier was still listed. Nobody noticed because the website and email continued to work normally. During an authorized test the analyst sends an AXFR request and receives the whole zone, including names for a test application and an internal database. The cause was not a sophisticated attack technique but a missed review after a migration, which is why configuration checks should be part of every change process.

2.10 Countermeasures

2.10.1 Restrict transfers by address

The main control is an access list that names the exact secondary servers permitted to request transfers and denies everyone else. An illustrative BIND-style configuration is shown below with documentation addresses.

```
zone "example.com" {
    type primary;
    file "db.example.com";
    allow-transfer { 192.0.2.53; };
    also-notify    { 192.0.2.53; };
};
```

2.10.2 Authenticate transfers with TSIG

Transaction Signatures (TSIG) use a shared secret key so that a primary and secondary can prove their identity to each other. Address lists can be spoofed in some situations, whereas a signed request cannot be forged without the key. Combining an address list with TSIG gives stronger protection.

2.10.3 Separate internal and external views

Split-horizon DNS serves internal records only to internal clients. The public zone then contains only what the world genuinely needs, so even a mistaken transfer would reveal little.

2.10.4 Monitor and review

DNS logs should be examined for AXFR and IXFR requests from addresses outside the approved list, and alerts should be raised for any such attempt. The zone should also be reviewed periodically so that stale records are removed.

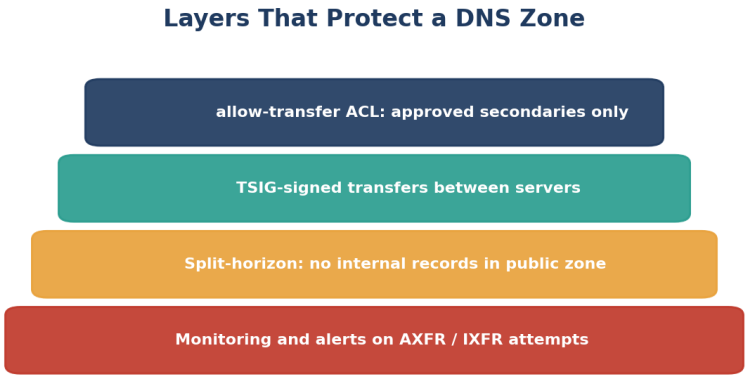


Figure 2.5: Layered protections for a DNS zone.

2.10.5 Detecting attempts

Name servers log transfer requests, and a careful administrator watches for them. An illustrative log line for a refused request is shown below with documentation addresses.

```
client 203.0.113.77#51234: zone transfer 'example.com/AXFR/IN' denied
```

A repeated pattern of denied transfers from one address suggests active reconnaissance and may justify blocking that address or alerting the security team.

2.10.6 Comparing the controls

Control	Strength	Limitation
allow-transfer ACL	Simple and effective against random requesters	Relies on source address; needs upkeep
TSIG signing	Cryptographic proof of identity between servers	Key management is required
Firewall rule on TCP 53	Blocks transfers at the network edge	Does not fix server configuration
Split-horizon views	Keeps private names out of public zone	Needs careful design and testing
Log monitoring	Detects attempts and misuse	Detection only; does not prevent

No single measure is sufficient. The strongest design uses an access list and TSIG at the server, a firewall at the edge, and monitoring to catch mistakes.

2.10.7 Other good practice

- Run at least two authoritative servers in separate locations.
- Use DNSSEC to protect the integrity of answers.
- Keep DNS software patched and expose only the services required.
- Use registrar locks and multi-factor authentication for the DNS management account.

2.11 Verification After Remediation

After the client applies changes, the analyst repeats the original AXFR test from the same unapproved source and confirms that every in-scope server now refuses the request. A second test from the approved secondary confirms that legitimate synchronisation still works, because a control that breaks normal operation is not a good fix.

Check	Expected result
AXFR from unapproved test host	Refused or failed on every in-scope server
Synchronisation from approved secondary	Succeeds, with matching SOA serial numbers
Public zone content	No internal or test records visible
Log review	Test requests appear in DNS logs and trigger alerts

2.11.1 DNS hardening checklist

Item	Status to record
Transfers limited to listed secondaries	Yes or no
TSIG keys in use and rotated	Yes or no
Internal names absent from public zone	Yes or no
Retired servers removed from ACLs and NS records	Yes or no
Registrar lock and MFA enabled	Yes or no
Transfer attempts logged and alerted	Yes or no

2.12 Reporting the Finding

The finding should be written so that a technical administrator can reproduce and fix it and a manager can understand its importance.

Report field	Entry
Title	Unrestricted DNS zone transfer
Affected asset	Authoritative name server named in scope
Evidence	Command, timestamp and trimmed output
Impact	Disclosure of hostnames and network layout
Severity	Rated on exposure, typically medium to high where internal names leak
Recommendation	Restrict transfers, add TSIG, separate views, monitor
Retest result	Recorded after the client applies fixes

2.13 Ethical and Legal Considerations

Zone-transfer tests may only be carried out against servers that the client has authorized. Testing a system without permission can breach computer misuse laws even when the request itself seems harmless. The analyst should keep requests to the minimum needed, protect any records obtained, and delete them once the engagement ends in line with the agreement.

2.14 Conclusion

Zone transfers keep authoritative DNS servers consistent, but if they are allowed to any requester they expose a complete map of the organization’s systems. The dig command lets an authorized analyst test this safely by sending an AXFR request and reading the response. A refusal indicates the expected behaviour, while a full answer should be examined for sensitive entries. Restricting transfers by address, signing them with TSIG, separating internal and external zones and monitoring requests together remove the exposure. A retest and a clear report then confirm the fix and document the lesson.

QUESTION 3: INTRODUCTION TO SOCIAL ENGINEERING – SOCIAL ENGINEERING ATTACKS AND COUNTERMEASURES

3.1 Introduction

Social engineering is the manipulation of people rather than machines. Instead of breaking encryption or exploiting software, the attacker persuades someone to hand over information or perform an action. The method works because people are trusting, helpful and often busy, and because security training has to compete with everyday pressure.

Phishing is the most widespread form. It uses fraudulent messages that appear to originate from a trusted sender and encourages the recipient to click a link, open a file or reveal credentials. Anti-virus, firewalls and patching offer little protection once an employee types a password into a convincing fake page.

In the scenario, staff receive an email that seems to come from the IT department. It says an urgent security update is needed and tells them to confirm their login details through a link. This is a textbook **credential-harvesting phishing attack** that relies on impersonation and urgency.

3.2 Objectives

1. Classify the attack described in the scenario.
2. Explain the psychological pressure the attacker applies.
3. Identify the warning signs in the message.
4. Describe what an employee should do before responding.
5. Show how each action prevents credential theft.
6. Recommend technical and organizational controls.
7. Explain the correct response if credentials were already entered.

3.3 Social Engineering in Context

Phishing is one member of a wider family of attacks that all exploit human behaviour. Seeing the family together helps explain why a single technical product cannot remove the risk.

Attack type	Channel	Typical method
Phishing	Email	Mass messages with a link or attachment
Spear phishing	Email	Message tailored to a named person or role
Whaling	Email	Targets senior executives with high-value requests
Vishing	Phone call	Caller poses as bank, IT or vendor staff
Smishing	SMS or chat	Short message with a malicious link
Pretexting	Any	Invented scenario to obtain information

Attack type	Channel	Typical method
Baiting	Physical or online	Infected USB drive or free download offered as a lure
Tailgating	Physical	Following an authorised person into a secured area

The scenario in this question is closest to ordinary phishing with an element of pretexting, and because it appears to come from an internal department it also resembles targeted impersonation.

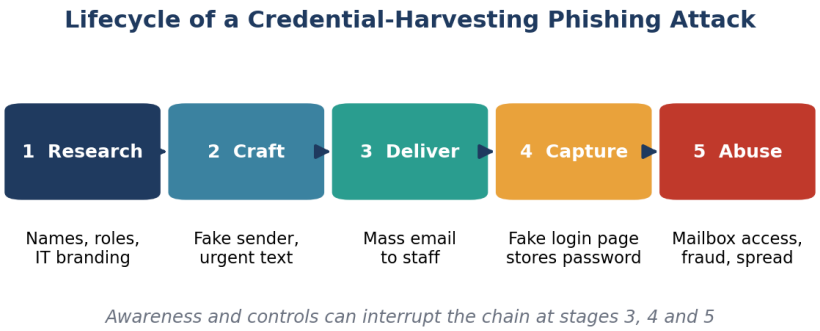


Figure 3.1: Lifecycle of a credential-harvesting phishing attack.

Describing the lifecycle shows that the attacker needs every stage to succeed. Interrupting any one stage, whether by filtering the delivery, alerting the user at capture or blocking abuse with multi-factor authentication, defeats the attack.

3.4 Classification of the Attack

The attack is **phishing by impersonation of the IT department**, specifically a credential-harvesting variant. The attacker's goal is to capture usernames and passwords through a fake login page and then use them to access email, files and business systems.

Scenario feature	Phishing characteristic
Sender claims to be IT	Impersonation of a trusted authority
Urgent security update	Pretext that explains the request
Request to verify login details	Credential harvesting objective
Link supplied in the email	Route to a counterfeit sign-in page
Pressure to act at once	Attempt to prevent verification

3.4.1 Related techniques

Pretexting supplies a believable story, here the security update. **Authority exploitation** uses the standing of the IT department. **Urgency** shortens the time for thought. **Spoofing** or look-alike domains make the sender appear genuine. The attack may later become **business email compromise** if the stolen account is used to send further messages to colleagues or suppliers.

3.5 Anatomy of the Suspicious Email

Figure 3.2 shows an illustrative version of the message with its warning signs labelled. The domain and link are invented placeholders.

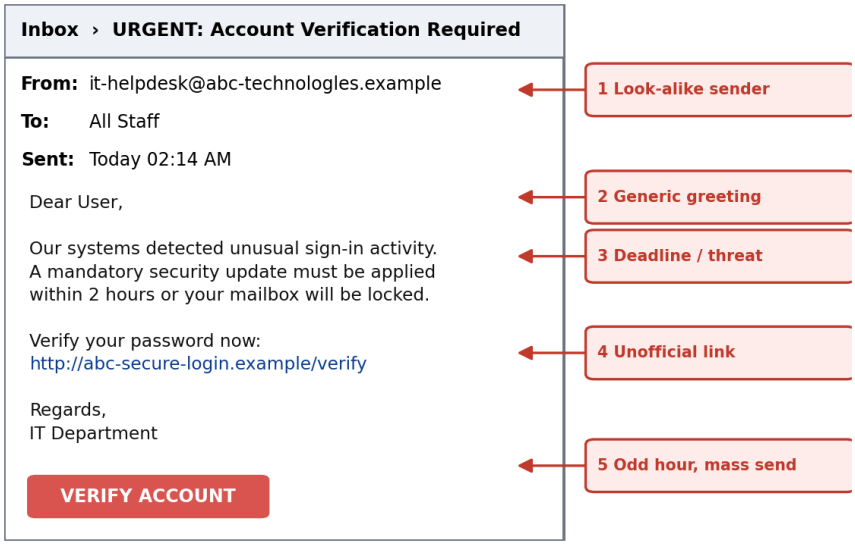


Figure 3.2: Illustrative phishing email with warning signs highlighted.

3.5.1 Indicators of phishing

- The sender address uses a slightly altered spelling of the company name.
- The greeting is generic instead of using the employee's name.
- The text threatens loss of access unless the user acts within a short time.
- The link leads to a domain that is not the company's own.
- The message asks for a password, which genuine IT teams do not request by email.
- It was sent at an unusual hour to a large group.

3.5.2 Link inspection

Attackers disguise malicious addresses in several ways, so employees should be taught to read a link from right to left, starting at the part immediately before the first single slash.

Trick	Illustration (placeholder)	How to spot it
Look-alike spelling	abc-technologles.example	Letter swapped or added in the company name
Company name as subdomain	abc.secure-login.example	Real domain is the part at the end, not the start
Added keywords	abc-login-verify.example	Official addresses do not add urgent words
Shortened link	Short URL service	Preview the destination before opening

Trick	Illustration (placeholder)	How to spot it
Display text differs	Text shows one site, link goes to another	Hover to compare the destination

3.5.3 Header checks

Technical staff can examine the message headers for authentication results. Failed SPF, DKIM or DMARC checks, a mismatch between the visible sender and the return path, or a reply-to address on another domain are strong signs of forgery. Employees are not expected to read headers themselves, but the security team can use them to confirm a report quickly.

3.6 Psychological Techniques Used

Principle	How the attacker applies it	Employee reaction targeted
Authority	Appears to be the IT department	Willingness to obey official instructions
Urgency	Short deadline for the update	Hurried action without checking
Fear	Warning of locked mailbox or breach	Wish to avoid loss or blame
Helpfulness	Presented as a routine security task	Desire to cooperate with IT
Social proof	Sent to all staff	Belief that others will comply

These pressures are effective because they act together. A person who is busy, anxious and sure that the message is official is less likely to pause and inspect the sender address.

3.7 Countermeasures Employees Should Follow

The most useful habit is to stop and verify. Figure 3.3 summarizes the decision path.

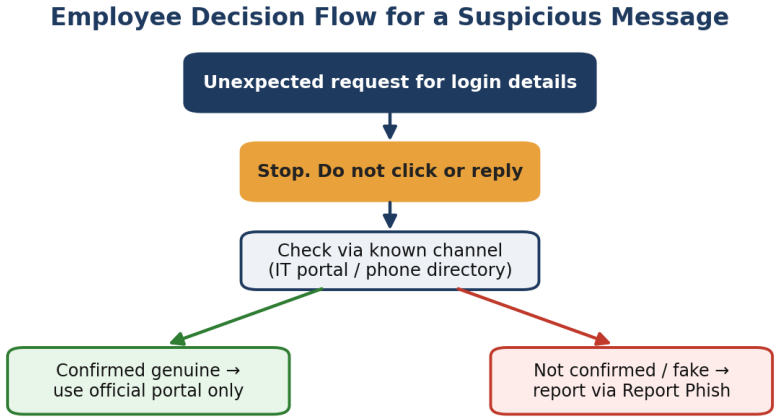


Figure 3.3: Employee decision flow for suspicious messages.

1. **Pause.** Do not click, download or reply while the request is unverified.
2. **Inspect.** Check the full sender address, hover over links to see the destination and look for generic wording.

3. **Verify independently.** Contact IT through the intranet, a known phone number or a ticketing portal, not through details in the email.
4. **Never share credentials by email or through a link.** Genuine updates are delivered through managed channels.
5. **Report.** Use the report-phishing button or forward the message to the security mailbox, then delete it.
6. **Warn colleagues** through the approved channel so others do not fall victim.

3.7.1 Quick reference for employees

Do	Do not
Check the sender address in full	Trust the display name alone
Type the company portal address yourself	Follow a link in an unexpected message
Call IT using a published number	Reply to the email asking if it is genuine
Report the message and delete it	Forward it to colleagues for opinions
Change your password via the official portal if unsure	Enter credentials on a page opened from the email

3.8 How These Actions Prevent Credential Theft

Employee action	Effect on the attack
Pausing	Removes the time pressure the attacker relies on
Inspecting sender and link	Exposes the fake domain before any data is typed
Verifying with IT	Confirms that no such update was requested
Not entering credentials	Leaves the fake page with nothing to capture
Reporting	Lets security block the sender and protect others
Warning colleagues	Reduces the success rate across the organization

A stolen password is useless to the attacker if it is never entered. Each action therefore breaks the chain at a different point.

3.9 Technical Controls for the Organization

Training alone cannot stop every message, so technical measures should reduce the number of phishing emails that arrive and limit the harm when one succeeds.

Control	Purpose
SPF, DKIM, DMARC	Authenticate the sending domain and block spoofed mail
Secure email gateway	Filter known malicious senders, links and attachments
Link rewriting and sandboxing	Check destinations when a link is clicked

Control	Purpose
Multi-factor authentication	Stop a stolen password from granting access on its own
Phishing-resistant MFA (FIDO2)	Bind login to the genuine site so fake pages fail
DNS and web filtering	Block access to newly seen or malicious domains
Endpoint protection	Detect malicious downloads and suspicious behaviour
External-sender banner	Visually flag messages from outside the company
Login anomaly monitoring	Detect unusual locations or impossible travel

3.9.1 Mapping to common attacker techniques

Security teams often describe incidents using the MITRE ATT&CK framework so that detection and response can be organised around known behaviour. The scenario maps to the following techniques.

Technique	ATT&CK reference	Relevance to the scenario
Phishing	T1566	Delivery of the deceptive email
Phishing for information	T1598	Request to verify login details
Valid accounts	T1078	Use of stolen credentials to sign in
Email collection	T1114	Reading or forwarding the victim's mailbox

3.10 Organizational Policies

- IT will never ask for passwords by email, chat or phone, and this rule is published to all staff.
- Security notices are posted on a single official channel that employees know.
- Urgent requests involving credentials or payments require a second form of confirmation.
- A simple, blame-free procedure exists for reporting suspicious messages.
- Password managers and unique passwords are required for work accounts.

3.11 Awareness Training

Effective training is short, regular and practical. Staff should see real examples, understand the psychological tricks and practise reporting. Simulated phishing exercises show which groups need more support, and the results should be used to improve training rather than to punish individuals.

Measure	Meaning
Click rate	Share of staff who clicked a simulated link
Report rate	Share who reported the simulated message
Time to report	How quickly the first report arrived
Repeat clickers	Staff who need additional coaching

A rising report rate is a stronger sign of a healthy security culture than a falling click rate alone.

3.11.1 Training calendar

Period	Activity	Audience
On joining	Short induction module and policy sign-off	New employees
Monthly	Two-minute tip with a real example	All staff
Quarterly	Simulated phishing campaign with feedback	All staff
Twice yearly	Workshop on voice and SMS attacks	Finance, HR, service desk
After incidents	Brief sharing of lessons learned	Affected teams

3.11.2 Remote and mobile staff

Employees who work from home or on mobile devices see more messages outside the protection of the office network and often read email on small screens that hide full sender addresses. Organizations should extend filtering and DNS protection to these devices, require managed device settings, and remind staff how to view the full address on a phone before tapping a link.

3.12 Response if an Employee Has Already Clicked

Mistakes happen, and speed matters more than blame. The employee should tell IT security immediately, even if unsure whether any data was entered. The response then follows a defined timeline.

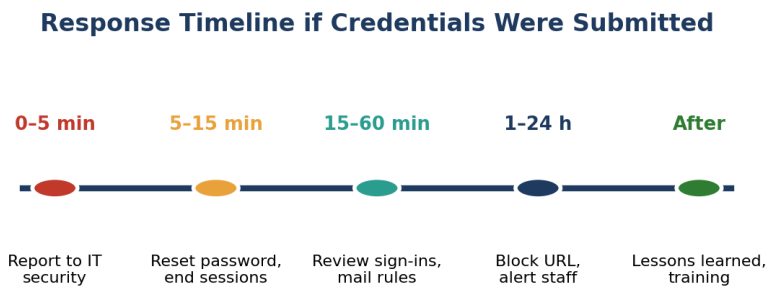


Figure 3.4: Response timeline after credential submission.

3.12.1 Actions for the security team

1. Reset the affected password and sign out all active sessions.
2. Re-register or review multi-factor authentication devices.
3. Examine sign-in logs and mailbox rules for forwarding or deletion rules set by the attacker.
4. Check whether the account sent messages to others.
5. Block the sender and the malicious link at the gateway and DNS filter.
6. Search other mailboxes for the same message and remove it.

7. Document the incident and update training with the lessons learned.

3.12.2 Illustrative incident narrative

In a hypothetical case, an employee enters a password on the fake page and realises a few minutes later that the address looked wrong. She reports the mistake to the service desk straight away. Within ten minutes the password is reset, her sessions are ended and multi-factor authentication devices are checked. The logs show one sign-in attempt from an unfamiliar country that failed at the MFA step, and no mailbox rules were created. The gateway then blocks the sender and the fake page, and the message is removed from all inboxes. Because the report was quick and blame-free, the attacker never gained a foothold. The organization uses the example in its next training session, with her permission and without naming her.

The case shows why a fast report and a second authentication factor matter more than perfect behaviour. Even a careful employee can be deceived, but a prepared organization can contain the damage.

3.13 Example of a Safe Employee Response

An employee who receives the message does not click the link. They open the company intranet directly, find that no update has been announced, call the IT service desk using the listed number and report the email through the phishing button. IT confirms that the message is fraudulent, blocks the sender and sends a short notice to staff. No credentials are lost and the attack ends there.

3.14 Suggested Phishing Report Format

A short, consistent report makes triage faster. Employees can be asked to supply the following when reporting a suspicious message, although a simple forward through the report button is always acceptable.

Item	Description
Time received	When the message arrived
Sender shown	Name and address displayed
Subject line	Exact wording
Action taken	Ignored, clicked, or entered details
Other recipients	Colleagues known to have received it

3.15 Building a Security-Aware Culture

Employees are most likely to report problems when they are encouraged and not criticised. Leaders should model good behaviour, share examples of attempted attacks and recognise staff who report suspicious messages. Over time this turns employees from the weakest link into an active layer of defence.

3.16 Conclusion

The scenario describes a credential-harvesting phishing attack that combines impersonation, urgency and a deceptive link. Its success depends on persuading staff to act before checking. Employees can defeat it by pausing, inspecting the message, verifying through trusted channels, refusing to enter credentials and reporting the email. The organization supports them with email authentication, filtering, multi-factor authentication, clear policies, regular training and a prepared incident response process. Together these measures make credential theft much harder and limit the damage if a mistake occurs.

OVERALL CONCLUSION

This assessment applied three core ethical hacking skills: gathering public information, testing DNS configuration and resisting social engineering.

Question 1 showed how passive footprinting with WHOIS, search engines, Hunter.io, Wappalyzer, BuiltWith, Certificate Transparency and passive DNS can describe an organization's public presence without touching its servers. Question 2 showed how the dig tool lets an authorized tester check whether a name server gives away its zone, and how access lists, TSIG, split views and monitoring close that gap. Question 3 analysed a phishing email that impersonates the IT department and explained how employee habits, technical controls and incident response work together to stop credential theft.

The common lesson is that security depends on both technology and judgement. Every activity must remain within an authorized scope, findings must be verified before they are reported, and recommendations must be practical. Organizations that know what they expose, configure their services carefully and prepare their people are far better placed to resist attack.

CODE OF CONDUCT

I G. PRANATHI [192472237] certify that this submission is my original work and that I have followed the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.